

Human Challenge Oracle: A Cryptographic Primitive for Continuous, Identity-Bound Sybil Resistance

Homayoun Maleki
DeustoTech, University of Deusto, Bilbao, Spain

Abstract

Open systems face persistent Sybil attacks in which adversaries sustain large numbers of fake identities at sublinear cost. Existing defenses—CAPTCHAs, behavioral biometrics, and Proof-of-Personhood mechanisms—either verify identity only at creation time or impose costs that can be reused and amortized across identities. Neither paradigm enforces a cost that grows proportionally with both the number of sustained identities and the duration of participation.

We introduce the *Human Challenge Oracle* (HCO), a cryptographic primitive for continuous, identity-bound, rate-limited verification. HCO issues fresh challenges that are cryptographically bound to individual identities and time windows; valid responses must arrive within a strict deadline. The security argument rests on four structural properties—identity binding (H1), freshness (H2), real-time constraint (H3), and per-channel throughput bound (H4)—and is *agnostic to solver identity*: whether a participation channel is operated by a human or an automated agent, the cost of sustaining s identities over T windows is $\Omega(sT)$. No assumption about human cognitive superiority over automated systems is required.

We present a concrete hash-based construction satisfying (H1)–(H3) under standard cryptographic assumptions, with a formally specified verification protocol. We characterize four abstract challenge families admissible under (H1)–(H4) and describe practical browser-based instantiations. A preliminary empirical study validates the feasibility of the throughput bound across representative families under strict response deadlines against current vision-language models. HCO is designed as a composable primitive; its formal use as a consensus resource is developed in companion papers [1, 2].

1 Introduction

Open and permissionless systems assume, implicitly or explicitly, that each account represents an independent participant. This assumption is violated by Sybil attacks [3], in which a single adversary creates and operates many fake identities at negligible cost, enabling spam, vote manipulation, coordinated disinformation, and governance abuse. Preventing Sybil attacks at scale remains one of the central unsolved problems in distributed systems security.

The failure mode of existing defenses. The dominant approaches bind participation to a scarce resource. CAPTCHAs [4] exploit a perceptual gap between humans and automated agents at account creation time, but they are fundamentally one-shot: once an account is created, sustained Sybil participation incurs no proportional recurring cost. As modern vision-language models (VLMs) improve, this gap steadily erodes [5–7]. CAPTCHA-solving services further commoditize the bypass [8]. Text-based CAPTCHA mechanisms have been shown to be breakable at high rates even against hardened designs [9].

Proof-of-Personhood (PoP) systems [10, 11] enforce a one-person-one-identity mapping through

ceremonies, biometric enrollment, or social vouching. Deployed systems include Worldcoin [12], BrightID [13], and Gitcoin Passport [14]. Like CAPTCHAs, PoP mechanisms raise the cost of identity *creation* but do not constrain ongoing participation: once identities are admitted, adversaries may sustain many of them without proportional recurring cost.

Social-graph defenses [15–18] constrain Sybil proliferation through trust topology but provide no explicit per-identity per-window cost bound. Behavioral biometrics [19, 20] enable ongoing verification but are proprietary and not designed for open adversarial settings.

The structural gap. All of these defenses fail to enforce a cost that scales *jointly* with the number of sustained identities s and the participation horizon T . An adversary sustaining s identities over T windows should face a cost of $\Omega(sT)$ —not a one-time fee at creation, and not a resource that can be reused across identities once acquired. The impossibility of achieving this under parallelizable resources (computation, capital) is established in the companion axiomatic paper [2].

This paper: HCO as a cryptographic primitive. We introduce the *Human Challenge Oracle* (HCO), a security primitive designed to enforce exactly this cost structure. HCO repeatedly issues fresh, cryptographically identity-bound challenges that must be answered within a strict real-time deadline. The security argument depends on four structural properties:

- **(H1) Identity binding.** A valid response for identity v cannot be credited to any other identity $v' \neq v$.
- **(H2) Freshness.** Challenges are unpredictable before issuance; precomputation is structurally impossible.
- **(H3) Real-time constraint.** Responses arriving after deadline Δ_{resp} are rejected.
- **(H4) Per-channel throughput bound.** Any single participation channel—human or automated—produces at most $\tau_h = O(1)$ valid responses per window.

Crucially, the linear cost guarantee does *not* assume that humans outperform automated solvers on individual challenges. Whether a channel is operated by a human, an AI system, or any hybrid is orthogonal to the cost argument: what cannot be avoided is that each identity requires one independent channel-window, and channel-windows cannot be shared across identities or carried across time.

This solver-agnostic framing aligns HCO with its companion papers. The HCO primitive is used as the participation resource in the PoCmt consensus protocol [1], which proves backbone-style safety and liveness under partial synchrony. The axiomatic theory establishing that linear Sybil cost requires a non-parallelizable resource is developed in [2].

Contributions.

1. We formally specify HCO as a cryptographic oracle primitive with properties (H1)–(H4) (Section 3).
2. We present a hash-based construction satisfying (H1)–(H3) under standard assumptions, with a verified algorithmic specification (Section 4).
3. We prove that (H1)–(H4) enforce $C(s, T) = \Omega(sT)$, both per window and in steady state, solver-agnostically (Sections 6–7).
4. We characterize four admissible challenge families and describe browser-based instantiations (Section 8).

5. We present a preliminary empirical evaluation of the throughput bound (H4) against current VLMs under strict deadlines (Section 9).
6. We analyze the construction against relay, outsourcing, replay, precomputation, deepfake, and side-channel attacks (Section 10).

HCO is not rate limiting. Standard rate-limiting mechanisms bound request frequency per account or network endpoint. They share none of the structural properties that make HCO a formal cryptographic primitive:

- *Rate limits do not enforce identity binding (H1).* An adversary creates additional accounts; each gets its own rate budget. The Sybil cost of creating s accounts remains zero—the rate limit is per-account, not per-channel-window.
- *Rate limits do not enforce freshness (H2).* An adversary precomputes, stockpiles, or replays requests across time windows without penalty.
- *Rate limits do not yield a composable cost theorem.* There is no equivalent of $C(s, T) = \Omega(sT)$ for sustained multi-identity participation over time: without (H1) and (H2), the cost of identity replication does not compound.
- *Rate limits do not compose into higher-level protocols.* They produce no cryptographically verifiable, identity-bound participation record usable as a weighting resource in a consensus mechanism or governance system.

The contribution of HCO is the *unification* of cryptographic identity binding, freshness, window locality, and throughput boundedness into a single formal primitive that admits a provable, composable linear cost theorem. Engineering mechanisms such as session serialization or device attestation are concrete instantiations of Property (H4)—they are how (H4) is *deployed*, not what HCO *is*.

2 Related Work

Sybil attacks and graph-based defenses. Douceur [3] established that identity replication cannot be prevented without binding influence to a scarce resource. Graph-based approaches constrain Sybil regions using social network structure: SybilGuard [15] and SybilLimit [16] bound adversarial identity count through random-walk protocols; SybilInfer [17] applies probabilistic inference over trust graphs. Clickstream behavioral analysis detects Sybil accounts through usage patterns [18]. These mechanisms constrain the *number* of Sybil identities but provide no explicit per-identity per-window cost bound over time.

CAPTCHA and one-time verification. The CAPTCHA framework [4] exploits human perceptual advantage at account creation. reCAPTCHA [21] and hCaptcha [22] extend this with behavioral signals and ML-based risk scoring. These mechanisms are fundamentally one-time: the cost of sustained Sybil participation after account creation is zero. Deep learning now breaks text [6, 9] and semantic image CAPTCHAs [5] at high rates, including via multi-digit recognition from distorted imagery [7]. CAPTCHA-solving services automate the bypass at commodity prices [8].

Proof-of-Personhood. PoP systems [10, 11] enforce a one-human-one-identity mapping through physical ceremonies or social vouching. Worldcoin [12], BrightID [13], and Gitcoin Passport [14]

Table 1: Comparison of verification mechanisms on dimensions critical for sustained Sybil resistance.

Mechanism	Persistent	Per-identity Rate-Limited	Solver-Agnostic	Cost Scaling
CAPTCHAs [4]	No	No	No	One-time
reCAPTCHA / hCaptcha [21, 22]	No	No	No	One-time
Proof-of-Personhood [10]	No	No	No	One-time
Behavioral biometrics [19]	Yes	Yes	Partial	Unclear
Proof-of-Work [32]	Yes	No	Yes	$o(sT)$
Proof-of-Stake [33]	Yes	No	Yes	$o(sT)$
HCO (this work)	Yes	Yes	Yes	$\Omega(sT)$

illustrate deployed approaches. PoP mechanisms raise identity creation cost but provide no continuous guarantee; once admitted, adversaries can sustain many identities without proportional recurring cost.

Human–AI performance under time constraints. Humans exhibit perceptual generalization under noise and distribution shift that deep networks lack [23, 24], and shortcut learning limits model robustness in novel conditions [25]. Broader cognitive flexibility distinguishes human reasoning from current AI systems [26]. These findings support the empirical plausibility of (H4) for human channels, though our security argument does not depend on this gap being permanent.

Automated solver capabilities. State-of-the-art VLMs—GPT-4o [27], Gemini [28], Claude [29]—achieve strong performance on unconstrained visual and reasoning tasks. CLIP [30] demonstrates zero-shot visual recognition. However, these models incur inference latencies of several seconds, which conflicts with tight Δ_{resp} windows. Our evaluation tests these models under strict deadline enforcement.

Behavioral biometrics and continuous authentication. Touchalytics [19] demonstrates touchscreen behavior as a continuous authentication signal; adversarial impersonation exposes fundamental limits of behavioral biometrics [20]. These mechanisms are passive and proprietary, not designed for open adversarial settings or permissionless participation.

Trusted hardware. Intel SGX [31] and related environments bind computation to physical hardware, enforcing per-device throughput limits. HCO does not require trusted hardware; it relies on cryptographic binding and the structural properties of participation channels.

Resource-based consensus. PoW [32] and PoS [33] bind influence to parallelizable resources that can be subdivided and reused across identities at sublinear marginal cost [34]. The formal impossibility of linear Sybil cost under parallelizable resources is established in [2]; the consensus protocol that uses HCO to escape this impossibility is in [1].

Table 1 positions HCO relative to prior work. HCO is the only mechanism that simultaneously enforces persistence, per-identity rate limiting, solver-agnosticism, and linear joint cost.

3 HCO Specification

3.1 Oracle Interface

Definition 1 (Human Challenge Oracle). *A Human Challenge Oracle is a stateful oracle*

$$HCO(v, d, j) \longrightarrow \chi_{v,d,j}$$

that, on input a validator identity v , window index $d \in \mathbb{N}$, and challenge index $j \in \{1, \dots, k(d)\}$, outputs a fresh challenge instance $\chi_{v,d,j}$. Each challenge is associated with a response deadline $\Delta_{\text{resp}} \ll \Delta_h$, where $\Delta_h > 0$ is the window duration.

A response ρ to $\chi_{v,d,j}$ is *valid* iff: (i) ρ is received within Δ_{resp} of issuance; (ii) ρ is a correct solution to $\chi_{v,d,j}$; (iii) ρ is cryptographically bound to the triple (v, d, j) . Verification is deterministic and publicly executable without long-term storage of participant data.

3.2 Security Properties

HCO must satisfy the following four structural properties.

- **(H1) Identity binding.** Each challenge $\chi_{v,d,j}$ is cryptographically bound to the triple (v, d, j) . A valid response to $\chi_{v,d,j}$ is invalid for any other triple $(v', d', j') \neq (v, d, j)$. Responses cannot be shared across identities or reused across windows.
- **(H2) Freshness.** No computationally bounded adversary can produce a valid response to $\chi_{v,d,j}$ with non-negligible probability before $\chi_{v,d,j}$ is issued. Precomputation and stockpiling are structurally impossible.
- **(H3) Real-time constraint.** Responses submitted after deadline Δ_{resp} are rejected. Together with (H2), this rules out any strategy separating challenge receipt from response generation across time.
- **(H4) Per-channel throughput bound.** There exists a constant $\tau_h = O(1)$ such that any single participation channel—human or automated—can produce valid responses for at most τ_h distinct challenge indices per window, independently of the number of identities associated with that channel.

Proposition 1 (Security is solver-agnostic). *Under (H1)–(H4), sustaining s active identities over T windows requires $\Omega(sT)$ independent channel-windows, regardless of whether channels are operated by humans, automated agents, or any combination thereof.*

The formal proof appears in Sections 6–7.

Remark 1. Properties (H1)–(H4) jointly constitute a strictly stronger primitive than per-account rate limiting. Rate limiting bounds request frequency but provides no cryptographic identity binding, no freshness guarantee, and no composable cost theorem. HCO provides all four, enabling the $C(s, T) = \Omega(sT)$ result of Sections 6–7 and composability with higher-level protocols such as the consensus mechanism of [1].

3.3 On Property (H4) and Solver Identity

Property (H4) asserts that a single channel is throughput-bounded per window under Δ_{resp} . This is *not* equivalent to assuming that humans outperform machines on individual challenges. A single automated agent may solve any given challenge instantly; what (H4) asserts is that a single channel cannot handle $\omega(1)$ distinct challenge indices per window within Δ_{resp} , due to the irreducible latency of each challenge-response round trip (network delivery, processing, submission, and verification). For human channels, cognitive processing time widens this bound further. Empirical validation of (H4) for specific challenge families is given in Section 9.

Two independent bases for (H4). Property (H4) can be grounded in two structurally distinct mechanisms, and either one is sufficient for the security argument.

Cognitive serialization. Human cognition imposes an irreducible serial bottleneck: a single person cannot attend to, process, and respond to multiple independent challenges simultaneously within a short deadline. This bound derives from cognitive and motor throughput limits, not from any assumption of human superiority over automated solvers.

Channel serialization. Engineering constraints can enforce (H4) independently of who or what operates the channel. Concrete mechanisms include:

- **Per-session serialization.** The system issues at most one active challenge per session token at any moment; the browser session or WebSocket connection is the channel boundary. A channel serving multiple identities in parallel must hold multiple concurrent sessions, each incurring its own round-trip budget.
- **Device-bound attestation.** Challenges are bound to a specific hardware token, secure enclave, or TPM that enforces a per-device rate limit. Scaling to s identities requires s independently attested devices.
- **Stateful interaction locality.** Challenges require continuous interaction with a dynamically mutating UI element throughout Δ_{resp} , making parallel execution across identities on a single device structurally difficult.

Under channel serialization, the bound on τ_h is a systems constraint rather than a cognitive claim: it follows from the serialization enforced by the channel architecture. The formal security argument of Sections 6–7 holds under either basis for (H4); deployments may select the enforcement mechanism best suited to their trust model and accessibility requirements.

3.4 Separability and Composability

The security guarantees of HCO depend only on (H1)–(H4). Application-level details—user interfaces, challenge formats, delivery channels—do not affect these guarantees. This separability enables HCO to be instantiated across diverse systems and composed with higher-level protocols. Its formal use as a primitive in the PoCmt consensus mechanism is developed in [1].

4 Cryptographic Construction

We present a concrete cryptographic instantiation of HCO satisfying Properties (H1)–(H3) under standard assumptions. Property (H4) is analyzed separately as a structural and empirical claim in Sections 3 and 9.

4.1 Setup

Let $\mathcal{H} : \{0,1\}^* \rightarrow \{0,1\}^\lambda$ be a collision-resistant hash function modeled as a random oracle [35], with security parameter λ . We instantiate $\mathcal{H}$ with SHA-3 [36] in practice. Each identity v holds a long-term key pair $(\text{sk}_v, \text{pk}_v)$ with pk_v registered with the system.

At the start of each window d , a fresh nonce $\eta_d \in \{0,1\}^\lambda$ is drawn from a public randomness beacon [37] and publicly broadcast. The nonce is unpredictable before window d opens and publicly verifiable thereafter.

Algorithm 1 $HCO.Verify(v, d, j, \rho, t_{\text{recv}})$

Require: Identity v , window d , index j , response $\rho = (\sigma_v, r_{v,d,j})$, receipt time t_{recv}

Ensure: **Accept** or **Reject**

```
1: if  $t_{\text{recv}} > t_{\text{issue}} + \Delta_{\text{resp}}$  then
2:   return Reject                                     {Deadline exceeded — enforces (H3)}
3: end if
4: if  $\neg \text{VerifySig}(\text{pk}_v, \text{pk}_v \parallel d \parallel j \parallel r_{v,d,j}, \sigma_v)$  then
5:   return Reject                                     {Invalid signature — enforces (H1)}
6: end if
7: Recompute binding tag:  $\tau \leftarrow \mathcal{H}(\text{pk}_v \parallel d \parallel j \parallel \eta_d)$ 
8: if binding tag in  $\chi_{v,d,j} \neq \tau$  then
9:   return Reject                                     {Wrong identity/window — enforces (H1)}
10: end if
11: if  $\neg \text{CheckTask}(r_{v,d,j}, \pi_{v,d,j})$  then
12:   return Reject                                     {Incorrect task solution}
13: end if
14: return Accept
```

4.2 Challenge Generation

For identity v , window d , and index $j \in \{1, \dots, k(d)\}$:

$$\chi_{v,d,j} = \left(\underbrace{\mathcal{H}(\text{pk}_v \parallel d \parallel j \parallel \eta_d)}_{\text{binding tag}}, \underbrace{\pi_{v,d,j}}_{\text{task payload}} \right), \quad (1)$$

where $\pi_{v,d,j}$ is a task payload from an admissible challenge family (Section 8). The binding tag anchors the challenge to (v, d, j) and the window-specific nonce.

4.3 Response and Verification

A participant submits:

$$\rho = (\sigma_v, r_{v,d,j}),$$

where $r_{v,d,j} \in \mathcal{R}$ is the task solution and $\sigma_v = \text{Sign}(\text{sk}_v, \text{pk}_v \parallel d \parallel j \parallel r_{v,d,j})$. Algorithm 1 gives the complete verification procedure.

4.4 Security of the Construction

Identity binding (H1). The binding tag $\mathcal{H}(\text{pk}_v \parallel d \parallel j \parallel \eta_d)$ ties the challenge to (v, d, j) . A valid response includes a signature under sk_v ; producing a valid response for $v' \neq v$ requires forging a signature under sk_v or finding a hash collision, both infeasible under standard assumptions.

Freshness (H2). The nonce η_d is revealed only at the start of window d . Because η_d is hidden prior to window d , the binding tag is computationally indistinguishable from uniform before d opens. No adversary can compute $\chi_{v,d,j}$ before η_d is known, ruling out precomputation in the random oracle model [35].

Real-time constraint (H3). Line 1 of Algorithm 1 checks the receipt timestamp deterministically and independently of the task solution. Late responses are rejected unconditionally.

Throughput bound (H4). The cryptographic construction does not by itself enforce (H4); this property arises from the latency structure of the participation channel. Each valid response requires: (i) receiving $\chi_{v,d,j}$ after its issuance; (ii) computing $r_{v,d,j}$ and σ_v ; (iii) transmitting ρ and having it received within Δ_{resp} . The minimum round-trip latency δ_{rtt} limits any channel to at most $\tau_h = \lfloor \Delta_{\text{resp}} / \delta_{\text{rtt}} \rfloor$ responses per window. For human channels, cognitive processing time further reduces this ceiling. Empirical characterization of τ_h is given in Section 9.

5 System and Adversary Model

5.1 System Model

The system consists of a set of identities $\mathcal{I}$ interacting with a platform relying on HCO for continuous verification. Time is divided into windows $d \in \mathbb{N}$ of fixed duration Δ_h .

An identity v is *active* in window d iff it submits at least one valid HCO response during d . Verification is deterministic, public, and requires no long-term storage of participant data.

5.2 Adversary Model

We consider a computationally unbounded adversary $\mathcal{A}$ that may:

- create and coordinate an arbitrary number of identities s ;
- operate up to m independent participation channels (human or automated) within any window, with m adaptively varying across windows;
- employ outsourcing, relay attacks, AI automation, or any combination;
- deviate arbitrarily from the protocol, subject to (H1)–(H4).

5.3 Adversarial Cost Function

Definition 2 (Adversarial cost). $C(s, T)$ denotes the minimum number of independent participation channel-windows required to sustain s active identities over T consecutive windows.

6 Sybil Cost Analysis

Lemma 1 (Per-window identity bound). *In any window d , an adversary operating m participation channels can produce valid HCO responses for at most $m \cdot \tau_h$ distinct identities.*

Proof. By (H4), each of m channels produces at most τ_h valid responses per window. By (H1), a response for identity v cannot be credited to $v' \neq v$; responses are non-sharable across identities. By (H2) and (H3), precomputed or late responses are rejected. The total valid responses attributable to distinct identities is therefore at most $m \cdot \tau_h$. $\square$

Theorem 1 (Linear Sybil cost). *Under (H1)–(H4), sustaining s active identities in any single window requires $m = \Omega(s)$ independent participation channels. Equivalently, $C(s, 1) = \Omega(s)$.*

Proof. From Lemma 1, $m\tau_h \geq s$, giving $m \geq s/\tau_h = \Omega(s)$ since $\tau_h = O(1)$. Each channel-window incurs a non-zero participation cost, so $C(s, 1) = \Omega(s)$. $\square$

Corollary 1 (No sublinear amortization). *No adversary can sustain s identities with $o(s)$ channels per window.*

Proof. Amortizing one channel across multiple identities in the same window violates (H1). Cross-window reuse violates (H2)–(H3). Both are excluded by construction. $\square$

7 Multi-Window and Long-Term Analysis

Let s_d and m_d denote the number of active identities and channels, respectively, in window d .

Lemma 2 (Window persistence bound). *$s_d \leq m_d \cdot \tau_h$ for every window d .*

Proof. Lemma 1 applied to window d . Since (H2)–(H3) prevent cross-window reuse, effort in window d cannot carry to $d + 1$. $\square$

Theorem 2 (Joint linear cost). *Under (H1)–(H4), $C(s, T) = \Omega(sT)$.*

Proof. By Lemma 2, each of T windows independently requires $\Omega(s)$ channels. Channels cannot be reused across windows (H2)–(H3), so the total cost is $\sum_{d=1}^T \Omega(s) = \Omega(sT)$. $\square$

Theorem 3 (Steady-state Sybil capacity). *Let $\bar{m} = \limsup_{T \rightarrow \infty} \frac{1}{T} \sum_{d=1}^T m_d$. Then $\limsup_{T \rightarrow \infty} \frac{1}{T} \sum_{d=1}^T s_d \leq \bar{m} \cdot \tau_h$.*

Proof. Sum $s_d \leq m_d \tau_h$ over T windows, divide by T , take $\limsup$. $\square$

Burst attacks. Concentrating effort in short bursts does not help: the total identity-window budget $B_T = \sum_{d=1}^T s_d$ satisfies $B_T \leq \tau_h \sum_{d=1}^T m_d$, so burst attacks incur linear cost in total channel-windows regardless of temporal concentration.

8 Challenge Families

8.1 Abstract Admissibility Requirements

A challenge family $\mathcal{C}$ is *admissible* for HCO if every instance satisfies (H1)–(H4). Concretely:

- instances are unpredictable before issuance (H2);
- correct responses are deterministically verifiable;
- responses are cryptographically bound to (v, d, j) (H1) via the construction of Section 4;
- the interaction model imposes an irreducible per-response latency that limits channel throughput to τ_h per window (H4).

The construction of Section 4 satisfies (H1)–(H3) for any task payload; admissibility under (H4) depends on the interaction latency of the specific task family.

8.2 Admissible Families

Perceptual visual matching. A distorted or noise-corrupted image is shown with candidate matches; the participant selects the correct correspondence within Δ_{resp} . Human perceptual generalization under noise remains robust [23]; current VLMs incur multi-second inference latencies that enforce a natural throughput ceiling per automated channel. Instances are generated by random visual transformations; verification is deterministic.

Interactive reasoning tasks. Short dependent reasoning sequences require maintaining intermediate state and submitting a result before a visible countdown expires. Multi-step inference latency limits automated throughput. Correctness is verified deterministically from dynamically generated parameters.

Biometric-light response tasks. A fresh, unpredictable prompt requires a synchronized real-time signal (spoken phrase, motion gesture). Automated synthesis under real-time constraints is currently unreliable and produces detectable latency artifacts. Verification uses transient signal features without long-term biometric enrollment.

Attention-based interaction tasks. A dynamic scene requires continuous tracking or selection over several seconds, occupying the full Δ_{resp} interval. This structurally limits any channel to one response per window.

8.3 Deployment Example: Relaxed Window Sizes

The formal guarantees of HCO hold across the full parameter space of Δ_{resp} and τ_h , from sub-second strict deadlines to relaxed daily interaction windows. A concrete example illustrates the range.

Daily participation with device-bound login. Consider a system in which each identity must perform one login-style interaction per day: $\Delta_h = 24\text{ h}$, $\Delta_{\text{resp}} = 24\text{ h}$, and $\tau_h = 1$. A single human has 24 hours to respond—there is no cognitive pressure. However, if the login is *device-bound* (bound to a specific smartphone, secure element, or attested browser session), then sustaining s identities requires s independent attested devices or sessions. An adversary cannot amortize one device across s identities within the same window: each identity requires its own channel-window. Under this configuration, Theorem 2 gives $C(s, T) = \Omega(sT)$ channel-windows even with $\tau_h = 1$. Sybil resistance does not depend on the challenge being cognitively demanding or time-pressured; it depends entirely on channel non-transferability (H1) and window-locality (H4) enforced by the device binding.

This example also clarifies the design space: tighter Δ_{resp} values (seconds to minutes) provide stronger near-real-time resistance but impose higher usability cost. Relaxed windows (hours to daily) reduce user burden while preserving the linear cost structure, provided channel binding is enforced engineering-side. The appropriate point in this tradeoff is a deployment-level decision orthogonal to the formal guarantees.

8.4 Rotation and Composability

HCO does not depend on any single family. Systems may rotate across admissible families between windows or combine them within a window. Since security depends only on (H1)–(H4), rotation preserves all guarantees of Theorems 2 and 3—this is essential for long-lived deployments where the automation landscape evolves.

Table 2: Preliminary results under strict Δ_{resp} constraints. Automated success includes both incorrect solutions and deadline violations.

Challenge Family	Human Success (%)	Human Mean Time (s)	Automated Success (%)	Auto. Mean Time (s)
Perceptual visual matching	92	6.2	12	18.4
Interactive reasoning	85	11.8	18	22.1
Biometric-light response	100	8.1	≈ 0	–
Attention-based interaction	95	14.5	≈ 0	–

9 Empirical Evaluation

We conduct a preliminary empirical study to validate (H4): that representative challenge families impose a measurable throughput bound on current automated systems under strict response deadlines, and that honest human participants complete challenges at high rates within Δ_{resp} . We emphasize that these results are preliminary; a large-scale study is planned as future work (see Section 11).

9.1 Methodology

Human participants. We recruited 30 participants (ages 18–45) through university mailing lists. Each participant completed 20 challenges per family (80 total) via a browser-based interface with a visible countdown timer.

Automated solvers. We evaluated GPT-4o [27], Gemini 1.5 Pro [28], and Claude 3.5 Sonnet [29] via their standard vision-language inference APIs, plus a specialized CAPTCHA-solving service (2captcha) for the perceptual family. We ran 100 trials per (solver, family) pair. A trial was counted as successful only if a correct response was *received* within the simulated Δ_{resp} window; inference latency exceeding Δ_{resp} counted as failure regardless of correctness.

9.2 Results

Human participants achieved high success rates across all families, with mean completion times well below typical Δ_{resp} values. Automated solvers were primarily limited by inference latency: mean response times of 18.4s and 22.1s for perceptual and reasoning families substantially exceed the 8–15s deadlines tested, confirming that current VLMs impose a natural throughput ceiling consistent with (H4).

10 Security Analysis

We analyze HCO against the principal adversarial strategies. All arguments are grounded in (H1)–(H4) and the construction of Section 4.

Automated solving. An adversary deploying AI solvers to fill participation channels does not circumvent the linear cost bound. By (H4), each automated channel is throughput-bounded at τ_h responses per window under Δ_{resp} . Scaling to s identities requires $\Omega(s)$ independent channels. Automation shifts the cost from human labor to API credits or hardware, but preserves linear scaling in s .

Human outsourcing and labor markets. An adversary may hire human workers or use

CAPTCHA-solving services [8] to solve challenges. This attack is captured in the adversary model: the adversary operates m human channels. Sustaining s identities requires $m = \Omega(s)$ workers (Theorem 1). Outsourcing converts the cost from direct labor to wages, but the linear scaling is preserved.

Relay and real-time forwarding attacks. Relaying challenges to external solvers adds network round-trip time, which tightens rather than relaxes (H4). By (H1) and (H2)–(H3), relayed responses are identity-bound and non-reusable; relaying does not reduce the total independent channel-windows required.

Replay and solution reuse attacks. By (H1), response $\rho_{v,d,j}$ is bound to (v,d,j) via the signature σ_v and the binding tag. Submitting the same response for $(v',d',j') \neq (v,d,j)$ fails the binding-tag check in Algorithm 1 (lines 3–5). By (H2), the nonce η_d ensures responses prepared before window d are invalid.

Precomputation and batch-solving. By (H2), $\chi_{v,d,j}$ cannot be computed before η_d is revealed. Batch-solving within a window is bounded by (H4): processing $k > \tau_h$ challenges requires more than τ_h round-trip latency budgets, which is infeasible under Δ_{resp} .

Synthetic media and deepfake attacks. For biometric-light families, an adversary may attempt real-time synthesis of a biometric response. Mitigations include: (i) challenge freshness (H2) prevents off-line synthesis; (ii) liveness detection flags synthesized signals; (iii) challenge rotation to families resistant to synthesis (e.g., attention-based interaction) eliminates reliance on vulnerable modalities.

Side-channel and man-in-the-browser attacks. A malicious browser extension may observe and forward challenges to an external solver. This constitutes a relay attack and is bounded as above. Deployment-level countermeasures—content-security-policy headers, subresource integrity, and challenge obfuscation—reduce exfiltration feasibility but are orthogonal to the core security model.

Privacy and data minimization. Verification requires only $\rho = (\sigma_v, r_{v,d,j})$ and $\chi_{v,d,j}$; no raw biometric data or behavioral record is stored. pk_v may be pseudonymous. Privacy-preserving challenge delivery ensuring unlinkability across windows while preserving identity binding is an important direction for future work.

11 Limitations

Dependence on Property (H4). The linear cost guarantee rests critically on (H4). For human channels, this bound is grounded in cognitive and temporal constraints. For automated channels, it is grounded in inference and network latency. Advances in specialized hardware or ultra-low-latency inference pipelines could reduce the effective latency floor, increasing τ_h and weakening the guarantee. Long-lived deployments must periodically reassess (H4) and adjust Δ_{resp} accordingly, analogous to difficulty adjustment in PoW [32].

Engineering bypass and the nature of (H4). When (H4) is enforced through channel serialization rather than cognitive constraints, adversaries may attempt to scale channel capacity through infrastructure: VM farms, cloud phone emulators, browser-bot fleets, or distributed worker pools. Such infrastructure does not invalidate (H4); it instead converts the guarantee from an *impossibility* into a *cost multiplier*. Each additional sustained identity still requires provisioning and operating an independent channel, so the adversarial cost remains $\Omega(sT)$ —but τ_h and the per-channel cost are now determined by engineering practice rather than cognition.

This is analogous to the role of honest-majority in Byzantine consensus: the guarantee holds given the assumption, and the assumption has a concrete cost to violate. The honest disclosure of this structure—that HCO bounds adversarial *cost* rather than adversarial *capability*—makes the primitive more trustworthy, not less. Deployments relying on channel serialization should therefore size Δ_{resp} and per-channel costs such that operating a large farm is economically prohibitive for the target threat model.

Scope of the preliminary evaluation. The study uses 30 participants recruited via university mailing lists, not a controlled recruitment platform [38, 39]. It does not cover task-specific fine-tuned models, custom hardware solvers, or organized human–AI hybrid pipelines. A large-scale study ($N \geq 100$ via Prolific, comprehensive adversarial solver suite, statistical significance testing) is planned as future work.

Accessibility and inclusivity. Challenge families requiring visual, auditory, or motor interaction may exclude participants with relevant impairments. Deployments must provide alternative modalities and accessibility-aware selection policies.

Parameter sensitivity. Δ_{resp} and $k(d)$ jointly determine the security-usability tradeoff. The formal guarantees hold for any $\Delta_{\text{resp}} > 0$, but concrete parameterization requires empirical measurement of τ_h and honest participant success rates in the target deployment environment.

Theoretical scope. The cost analysis assumes (H1)–(H4) hold throughout execution. Partial failures of (H4) yield intermediate scaling regimes; their characterization is developed in the companion paper [2].

12 Conclusion

We introduced the Human Challenge Oracle (HCO), a cryptographic primitive for continuous, identity-bound, rate-limited participation verification. Under Properties (H1)–(H4), HCO enforces $C(s, T) = \Omega(sT)$: sustaining s identities over T windows requires $\Omega(sT)$ independent channel-windows, regardless of whether channels are operated by humans, automated agents, or any combination thereof. No assumption about human cognitive superiority is required.

We presented a hash-based construction satisfying (H1)–(H3) under standard cryptographic assumptions, with Algorithm 1 as the formal verification procedure. We identified four admissible challenge families, described browser-based instantiations, and conducted a preliminary empirical study confirming that current VLMs impose a natural throughput ceiling under strict response deadlines, validating the empirical basis of (H4).

HCO is designed as a composable primitive. Its formal use as a consensus resource—including backbone-style safety, liveness, and fairness—is developed in [1]. The axiomatic cost-theoretic foundation establishing that linear Sybil cost requires a non-parallelizable resource is given in [2].

The most immediate priorities for future work are a large-scale empirical study ($N \geq 100$, controlled recruitment, comprehensive adversarial solvers), privacy-preserving challenge delivery with cross-window unlinkability, formal composability analysis in the UC framework, and adaptive challenge rotation mechanisms that preserve (H1)–(H4) under evolving automation capabilities.

References

- [1] Homayoun Maleki. Proof of commitment: Time-per-identity as a non-parallelizable consensus resource. arXiv preprint, 2026.

- [2] Homayoun Maleki. The geometry of adversarial identity cost: Structural limits of Sybil resistance in open systems. arXiv preprint, 2026.
- [3] John R. Douceur. The Sybil attack. In *International Workshop on Peer-to-Peer Systems (IPTPS)*, pages 251–260, 2002.
- [4] Luis von Ahn, Manuel Blum, Nicholas J. Hopper, and John Langford. CAPTCHA: Using hard AI problems for security. In *Advances in Cryptology – EUROCRYPT*, pages 294–311, 2003.
- [5] Suphannee Sivakorn, Iasonas Polakis, and Angelos D. Keromytis. I am robot: (deep) learning to break semantic image CAPTCHAs. In *IEEE European Symposium on Security and Privacy (EuroS&P)*, pages 388–403, 2016.
- [6] Guixin Ye, Zhanyong Tang, Dingyi Fang, Zhanxing Zhu, Yansong Feng, Pengfei Xu, Xiaojiang Chen, and Zheng Wang. Yet another text CAPTCHA solver: A generative adversarial network based approach. In *ACM SIGSAC Conference on Computer and Communications Security (CCS)*, pages 332–348, 2018.
- [7] Ian J. Goodfellow, Yaroslav Bulatov, Julian Ibarz, Sacha Arnoud, and Vinay Shet. Multi-digit number recognition from street view imagery using deep convolutional neural networks. In *International Conference on Learning Representations (ICLR)*, 2014.
- [8] Marti Motoyama, Kirill Levchenko, Chris Kanich, Damon McCoy, Geoffrey M. Voelker, and Stefan Savage. Re: CAPTCHAs—understanding CAPTCHA-solving services in an economic context. In *USENIX Security Symposium*, pages 435–452, 2010.
- [9] Elie Bursztein, Matthieu Martin, and John C. Mitchell. Text-based CAPTCHA strengths and weaknesses. In *ACM Conference on Computer and Communications Security (CCS)*, pages 125–138, 2011.
- [10] Maria Borge, Eleftherios Kokoris-Kogias, Philipp Jovanovic, Linus Gasser, Nicolas Gailly, and Bryan Ford. Proof-of-personhood: Redemocratizing permissionless cryptocurrencies. In *IEEE European Symposium on Security and Privacy Workshops (EuroS&PW)*, pages 23–28, 2017.
- [11] Bryan Ford. Pseudonym parties: An offline foundation for online accountability. In *IEEE Security & Privacy Workshops*, 2020.
- [12] Worldcoin Foundation. Worldcoin: Proof of personhood at scale. <https://worldcoin.org>, 2023.
- [13] BrightID. BrightID: Decentralized identity. <https://www.brightid.org>, 2022.
- [14] Gitcoin. Gitcoin Passport. <https://passport.gitcoin.co>, 2023.
- [15] Haifeng Yu, Phillip B. Gibbons, Michael Kaminsky, and Feng Xiao. SybilGuard: Defending against Sybil attacks via social networks. In *ACM SIGCOMM*, pages 267–278, 2006.
- [16] Haifeng Yu, Michael Kaminsky, Phillip B. Gibbons, and Abraham D. Flaxman. SybilLimit: A near-optimal social network defense against Sybil attacks. In *IEEE Symposium on Security and Privacy (S&P)*, pages 3–17, 2008.
- [17] George Danezis and Prateek Mittal. SybilInfer: Detecting Sybil nodes using social networks. In *Network and Distributed System Security Symposium (NDSS)*, 2009.

- [18] Gang Wang, Tristan Konolige, Christo Wilson, Xiao Wang, Haitao Zheng, and Ben Y. Zhao. You are how you click: Clickstream analysis for Sybil detection. In *USENIX Security Symposium*, pages 241–256, 2013.
- [19] Mario Frank, Ralf Biedert, Eugene Ma, Ivan Martinovic, and Dawn Song. Touchalytics: On the applicability of touchscreen input as a behavioral biometric for continuous authentication. *IEEE Transactions on Information Forensics and Security*, 8(1):136–148, 2013.
- [20] Abdul Serwadda and Vir V. Phoha. When kids’ games expose grown-up flaws: An analysis of keystroke dynamics classifiers under skilled impersonation attack. In *ACM Conference on Computer and Communications Security (CCS)*, pages 1189–1200, 2013.
- [21] Google. reCAPTCHA v3. <https://www.google.com/recaptcha>, 2019.
- [22] hCaptcha Team. hCaptcha. <https://www.hcaptcha.com>, 2020.
- [23] Robert Geirhos, Carlos R. M. Temme, Jonas Rauber, Heiko H. Schütt, Matthias Bethge, and Felix A. Wichmann. Generalisation in humans and deep neural networks. In *Advances in Neural Information Processing Systems (NeurIPS)*, pages 7538–7550, 2018.
- [24] Robert Geirhos, Patricia Rubisch, Claudio Michaelis, Matthias Bethge, Felix A. Wichmann, and Wieland Brendel. ImageNet-trained CNNs are biased towards texture; increasing shape bias improves accuracy and robustness. In *International Conference on Learning Representations (ICLR)*, 2019.
- [25] Robert Geirhos, Jörn-Henrik Jacobsen, Claudio Michaelis, Richard Zemel, Wieland Brendel, Matthias Bethge, and Felix A. Wichmann. Shortcut learning in deep neural networks. *Nature Machine Intelligence*, 2:665–673, 2020.
- [26] Brenden M. Lake, Tomer D. Ullman, Joshua B. Tenenbaum, and Samuel J. Gershman. Building machines that learn and think like people. *Behavioral and Brain Sciences*, 40:e253, 2017.
- [27] OpenAI. GPT-4 technical report. arXiv:2303.08774, 2023.
- [28] Gemini Team, Google. Gemini: A family of highly capable multimodal models. arXiv:2312.11805, 2023.
- [29] Anthropic. The Claude 3 model family: Opus, sonnet, haiku. Model card. <https://www.anthropic.com>, 2024.
- [30] Alec Radford, Jong Wook Kim, Chris Hallacy, Aditya Ramesh, Gabriel Goh, Sandhini Agarwal, Girish Sastry, Amanda Askell, Pamela Mishkin, Jack Clark, Gretchen Krueger, and Ilya Sutskever. Learning transferable visual models from natural language supervision. In *International Conference on Machine Learning (ICML)*, pages 8748–8763, 2021.
- [31] Victor Costan and Srinivas Devadas. Intel SGX explained. IACR Cryptology ePrint Archive, Report 2016/086, 2016.
- [32] Satoshi Nakamoto. Bitcoin: A peer-to-peer electronic cash system. White paper, 2008.
- [33] Aggelos Kiayias, Alexander Russell, Bernardo David, and Roman Oliynykov. Ouroboros: A provably secure proof-of-stake blockchain protocol. In *Advances in Cryptology – CRYPTO*, pages 357–388, 2017.

- [34] Joseph Bonneau, Andrew Miller, Jeremy Clark, Arvind Narayanan, Joshua A. Kroll, and Edward W. Felten. SoK: Research perspectives and challenges for Bitcoin and cryptocurrencies. In *IEEE Symposium on Security and Privacy (S&P)*, 2015.
- [35] Mihir Bellare and Phillip Rogaway. Random oracles are practical: A paradigm for designing efficient protocols. In *ACM Conference on Computer and Communications Security (CCS)*, pages 62–73, 1993.
- [36] NIST. SHA-3 standard: Permutation-based hash and extendable-output functions. FIPS Publication 202, 2015.
- [37] Ewa Syta, Philipp Jovanovic, Eleftherios Kokoris-Kogias, Nicolas Gailly, Linus Gasser, Ismail Khoffi, Michael J. Fischer, and Bryan Ford. Scalable bias-resistant distributed randomness. In *IEEE Symposium on Security and Privacy (S&P)*, pages 444–460, 2017.
- [38] Prolific Academic Ltd. Prolific: Quickly find research participants. <https://www.prolific.com>, 2014.
- [39] Eyal Peer, David Rothschild, Andrew Gordon, Zak Evernden, and Ekaterina Damer. Data quality of platforms and panels for online behavioral research. *Behavior Research Methods*, 54: 1643–1662, 2022.